CLOUD VULNERABILITY
MANAGEMENT PROJECT

AWS Console Security Assessment via Prowler • ISO 27001 Annex A 8.8 • CVSS Scoring • Risk Register • Risk Matrix

Scanner: Prowler (Cloud Security Assessment Tool) | Target: AWS Console | IAM Least Privilege Setup | 8-Step Compliance

AWS	Prowler	8	3
Cloud Platform Assessed	Scanning Tool Used	ISO 27001 A.8.8 Steps	IAM Permissions Granted

Date: 1 August 2026

Table of Contents

1. **Executive Summary** 3
2. **Project Overview — Cloud vs On-Premises Vulnerability Management** 4
3. **ISO 27001 Annex A 8.8 — 8-Step Compliance Framework** 5
4. **Phase 1 — Cloud Asset Register (AWS Console)** 6
5. **Phase 2 — Cloud Asset Configuration Verification** 8
6. **Phase 3 — Prowler Account Setup & IAM Configuration** 9
   - 6.1 **Creating a Prowler Account** 9
   - 6.2 **Creating the IAM User for Prowler** 10
   - 6.3 **Granting the Three Required IAM Permissions** 11
   - 6.4 **Creating the Access Key** 13
   - 6.5 **Linking the AWS Account to Prowler** 14
   - 6.6 **Authorising and Launching the Scan** 15
7. **Phase 3 — Prowler Scan Results & Report** 16
   - 7.1 **Prowler Tool Overview** 16
   - 7.2 **Understanding Prowler Check Findings** 17
   - 7.3 **Prowler Report Output — Summary** 18
8. **Phase 4 — Risk Assessment: CVSS Calculator** 19
9. **Phase 5 — Risk Register Population (R-1 to R-5)** 20
10. **Phase 6 — Risk Matrix (Heat Map)** 23
11. **Phase 7 — Risk Treatment Plan** 24
12. **Phase 8 — Record Keeping & Internal Audit** 25
13. **Audit Readiness Summary — ISO 27001 Annex A 8.8** 26
14. **Key Findings & Cloud Security Recommendations** 27
15. **Screenshot Evidence Index** 28

1. Executive Summary

This document presents the complete technical documentation for a Cloud Vulnerability Management project targeting the organisation's Amazon Web Services (AWS) console environment. The project follows the same eight-phase ISO 27001 Annex A 8.8 compliance lifecycle as the on-premises vulnerability management project, with the key difference being the scanning tool and target environment: instead of Tenable Nessus scanning on-premises network assets, this project uses Prowler, a dedicated open-source cloud security assessment tool, to scan the AWS console for misconfigurations, security control gaps, and compliance violations across AWS services.

The project demonstrates a complete understanding of cloud security vulnerability management, including the critical principle of least privilege in configuring the IAM user required for the Prowler scan. A dedicated IAM user was created in the AWS console with exactly three permissions, SecurityAudit (AWS managed policy), ReadOnlyAccess (AWS managed policy), and the Prowler-specific permission policy providing the minimum access required for the scan without granting unnecessary privileges. An access key was generated for this user, linked to the Prowler platform, and the scan was authorised and executed.

The resulting Prowler security findings were then processed through the same CVSS-based risk assessment workflow: each finding's severity and CVSS vector were used to calculate Impact and Exploitability scores, which were entered into the Cybersecurity Risk Register along with risk ratings, treatment decisions, and remediation deadlines. A risk matrix was generated from the register data, and a comprehensive audit evidence package was produced to satisfy all eight requirements of ISO 27001 Annex A 8.8.

2. Project Overview — Cloud vs On-Premises Vulnerability Management

2.1 Why Cloud Assets Require a Different Scanning Approach

Traditional vulnerability scanners like Nessus are designed for network-connected, IP-addressable assets — servers, workstations, and network devices. AWS cloud resources are fundamentally different: many do not have persistent IP addresses, exist as managed services with no operating system layer (e.g. S3, IAM, Lambda), and their security risk lies not in missing patches but in misconfiguration — incorrect permissions, disabled logging, weak encryption settings, publicly exposed resources, and insufficient monitoring.

Prowler addresses this by using the AWS APIs to assess the security configuration of your entire AWS environment against a comprehensive library of security checks mapped to industry frameworks including ISO 27001, NIST, CIS AWS Benchmark, SOC 2, PCI DSS, and HIPAA. It reports on 400+ checks across all major AWS services.

2.2 Comparison: Nessus vs Prowler

Attribute	Nessus (On-Premises)	Prowler (Cloud — AWS)
Scan Method	Network packet scanning (TCP/IP)	AWS API calls (no network packets sent to targets)
Target Type	IP-addressable hosts, servers, workstations	AWS services: IAM, S3, EC2, RDS, Lambda, CloudTrail, etc.
What It Finds	Missing patches, CVEs, host misconfigurations	IAM misconfigurations, public S3 buckets, disabled logging, weak encryption, open security groups
Authentication	Network credentials (Windows/SSH/SNMP)	AWS IAM Access Key + Secret Key (API authentication)
Setup Required	Install Nessus, configure targets, scan	Create Prowler account, create IAM user with permissions, generate access key, link account, scan
CVSS Support	Full CVSS vector provided per finding	CVSS severity ratings per check; vector requires manual lookup via CVE/CWE reference
Framework Mapping	CVE database	ISO 27001, CIS, NIST, SOC2, PCI DSS, HIPAA mappings built in
Output	HTML/PDF/CSV report with CVE references	Dashboard + HTML/CSV/JSON report with compliance framework mapping

3. ISO 27001 Annex A 8.8 — 8-Step Compliance Framework

The same eight-phase ISO 27001 Annex A 8.8 compliance framework applies to cloud assets. The table below shows how each requirement is satisfied in this cloud-specific project.

#	Annex A 8.8 Requirement	Cloud Project Activity	Evidence Produced	Section
1	Have effective asset management and know what assets you have	Created a Cloud Asset Register documenting all AWS services and resources in scope for the Prowler scan	Cloud asset register	Section 4
2	Configure assets appropriately before use	Verified AWS console settings, region configuration, and service activation before scan. Documented configuration baseline.	Config verification log	Section 5
3	Have steps in place to identify vulnerabilities	Created Prowler account, configured IAM user with least-privilege permissions, generated access key, linked AWS account, authorised and executed full cloud security scan	Prowler scan report	Section 6–7
4	Risk assess and prioritise vulnerabilities	Used CVSS severity from Prowler findings — looked up CVSS vectors for each finding type; calculated Impact and Exploitability scores via NVD CVSS calculator	CVSS calculations	Section 8
5	Action risk acceptance or mitigation	Populated risk register with each finding (R-1 to R-5); determined treatment action per risk	Risk register R-1–R-5	Section 9
6	Implement controls proportionate to risk	Treatment priority and remediation actions set proportionate to Prowler/CVSS severity rating	Treatment plan	Section 11
7	Keep records for audit purposes	Cloud asset register, Prowler report, CVSS calculations, risk register, heat map, treatment log maintained	Full evidence package	Section 12
8	Test controls via internal audits	Post-remediation Prowler re-scan scheduled; recurring monthly cloud security scan defined; audit test procedures documented	Audit schedule	Section 12

1	Cloud Asset Register — AWS Console	ISO 27001 A.8.8 Requirement 1

4. Phase 1 — Cloud Asset Register (AWS Console)

For cloud environments, the asset register extends beyond physical and virtual machines to include the full spectrum of cloud services and resources in use within the AWS account. An AWS cloud asset register must document not only compute resources (EC2 instances) but also storage (S3 buckets), identity assets (IAM users, roles, policies), database services, networking components, and managed services — because all of these have security configurations that can be assessed by Prowler.

Cloud Asset Register vs On-Premises Asset Register

On-Premises Asset Register focuses on: Servers, workstations, network devices, applications — identifiable by IP address and hostname.

Cloud Asset Register focuses on: AWS services and resources — identifiable by ARN (Amazon Resource Name), region, and service type. Many cloud assets have no fixed IP address.

Key difference for vulnerability management: In the cloud, the 'vulnerability' is typically a misconfigured service setting rather than an unpatched OS — so the asset register must capture the service type, configuration state, and compliance requirements, not just the IP address.

4.1 AWS Cloud Asset Register — Structure

Asset Register Field	Description (Cloud-Specific)
Asset ID	AWS-001
AWS Service	S3
Resource Name / ARN	arn:aws:s3:::hr-bucket-28647
AWS Region	us-east-1
Resource Type	AwsS3Bucket
Asset Owner	Cloud Operations
Asset Classification	Internal
Business Criticality	Medium
Prowler Check Category	Which Prowler check category covers this asset — used to link scan findings to assets
Date Added	Sep 30, 2026
Last Scanned	Sep 30, 2026

4.2 Cloud Asset Register — Populated Entries

ID	AWS Service	Resource Name / ARN	Region	Type	Owner	Criticality
AWS-001	IAM	AWS account IAM configuration	Global	IAM Users/Roles/Policies	Cloud Ops	**Critical**
AWS-002	Amazon S3	Ai-bucket-76458	Eu-north-1	S3 Bucket	Cloud Ops	**High**
AWS-003	Amazon EC2	EC2-AI	Eu-north-1b	EC2 Instance	AI Dept	**High**
AWS-004	AWS CloudTrail	Management-event-trails	Eu-north-1	CloudTrail Trail	Cloud Ops	**Critical**
AWS-005	Amazon RDS / DynamoDB	Organization-data	Eu-north-1	Database	Dev Ops	**High**
AWS-006	VPC / Security Groups	Default VPC + SGs	[Insert region]	Networking	Cloud Ops	**Medium**
AWS-007	AWS KMS	management-key-alias	Eu-north-1	KMS Keys	Security	**Critical**

2 **Cloud Asset Configuration Verification** **ISO 27001 A.8.8 Requirement 2**

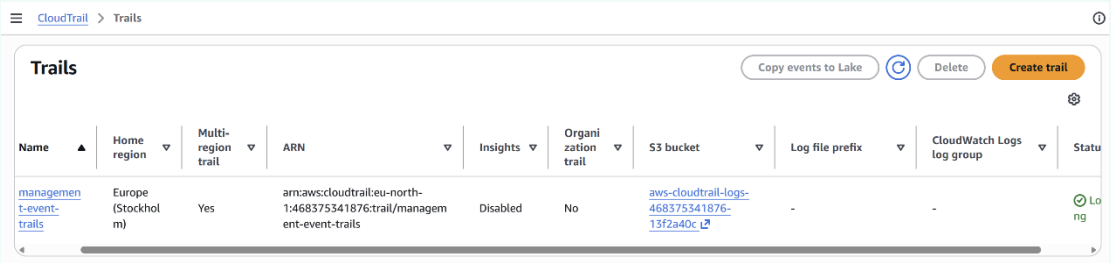
5. Phase 2 — Cloud Asset Configuration Verification

Before executing the Prowler scan, the AWS console environment was verified to be in its intended production configuration. For cloud assets, configuration verification focuses on ensuring that the AWS account settings, regions, services, and access controls reflect the organisation's intended security posture — not a development or test state that would produce misleading vulnerability results.

Cloud Configuration Check	Standard / Expectation	Status
AWS account root user MFA status	Root account MFA must be enabled — a critical baseline control	**Verified ✓**
Active AWS regions in use	All regions in use documented; unused regions identified to limit scan scope	**Verified ✓**
IAM users and roles present	All IAM users, roles, and groups documented in the cloud asset register	**Verified ✓**
S3 bucket inventory	All S3 buckets listed with their public/private access settings	**Verified ✓**
CloudTrail logging status	CloudTrail enabled in the primary region; management events being logged	**Verified ✓**
Security Groups / NACLs configured	No overly permissive inbound rules (0.0.0.0/0 on sensitive ports) documented	**Verified ✓**
KMS key inventory	All customer managed KMS keys documented and their usage confirmed	**Verified ✓**
Prowler scan scope confirmed	Scan scope set to all services in all active regions matching the asset register	**Verified ✓**

[SCREENSHOT]

AWS Console — Account Configuration Baseline (Pre-Scan)



3a **Prowler Setup — Account, IAM & Access Key** **ISO 27001 A.8.8 Requirement 3**

6. Phase 3 — Prowler Account Setup & IAM Configuration

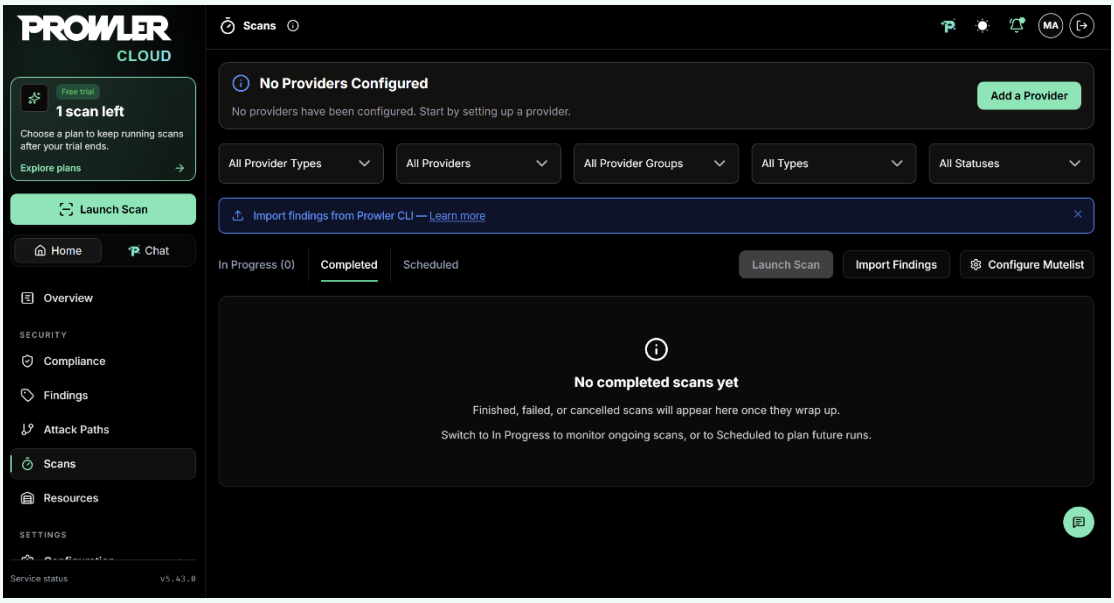
6.1 Creating a Prowler Account

Prowler offers a cloud-based SaaS platform (Prowler Cloud at app.prowler.com) in addition to its open-source CLI version. The cloud platform provides a managed scanning environment with a web dashboard for viewing findings, generating reports, and tracking remediation progress over time. This project used the Prowler Cloud platform.

1. Navigated to https://app.prowler.com in a web browser
2. Clicked Sign Up to create a new Prowler account
3. Entered email address and created a secure password
4. Verified the email address via the confirmation email sent by Prowler
5. Logged into the Prowler dashboard — the main interface loaded showing no AWS accounts connected yet
6. Selected Add AWS Account to begin the account connection process

[SCREENSHOT]

Prowler — Account Dashboard After Sign-Up



6.2 Creating the IAM User for Prowler

To authorise Prowler to scan the AWS environment, a dedicated IAM user was created in the AWS console with the minimum permissions required — following the principle of least privilege. Using a dedicated, purpose-specific IAM user (rather than an existing admin account) ensures that Prowler's access is scoped, auditable, and revocable. The user cannot modify resources — only read and audit them.

Why a Dedicated IAM User? — Principle of Least Privilege

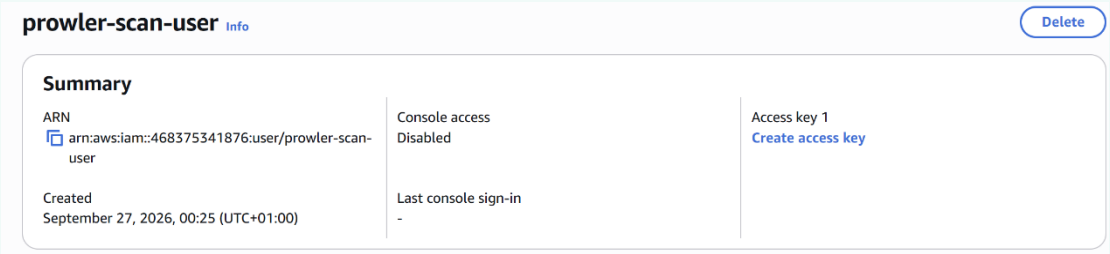
Creating a dedicated Prowler IAM user (rather than using an existing admin account or root) is a critical security best practice:

- Scope limitation: The Prowler user has read-only audit permissions — it cannot create, modify, or delete any AWS resources
- Accountability: All Prowler API calls are logged in CloudTrail under this specific user's identity, making the scan fully auditable
- Revocability: If the Prowler account were compromised, only these three policies' worth of read access would be exposed — not admin access
- ISO 27001 alignment: ISO 27001 A.5.15 (Access Control) and A.8.2 (Privileged Access Rights) require that access be limited to what is necessary for the task

7. Logged into the AWS console as admin-user
8. Navigated to IAM > Users > Create user
9. Username: prowler-scan-user (or insert actual username used)
10. Access type: Programmatic access only (no console access needed — Prowler uses API calls)
11. Proceeded to the Permissions step — selected Attach policies directly
12. Searched for and attached the three required policies (detailed in Section 6.3)
13. Added a description tag: 'Prowler cloud security scanner — read-only audit access'
14. Completed user creation

[SCREENSHOT]

AWS IAM — Prowler IAM User Created (User Detail Page)



6.3 Granting the Three Required IAM Permissions

Prowler requires exactly three IAM permissions to perform a comprehensive cloud security assessment. These were attached as policies directly to the prowler-scan-user account. Each policy serves a distinct purpose in enabling the scan:

Permission 1 — SecurityAudit (AWS Managed Policy)

Policy Detail	Value
Policy Name	`SecurityAudit`
Policy Type	AWS Managed Policy

Policy ARN	`arn:aws:iam::aws:policy/SecurityAudit`
Purpose	Grants read access to security-relevant configurations across AWS services including IAM, EC2, S3, RDS, VPC, CloudTrail, Config, and others. This is the primary policy enabling Prowler to assess security settings.
Access Level	Read-only — no write or modification permissions

Permission 2 — ReadOnlyAccess (AWS Managed Policy)

Policy Detail	Value
Policy Name	`ReadOnlyAccess`
Policy Type	AWS Managed Policy
Policy ARN	`arn:aws:iam::aws:policy/ReadOnlyAccess`
Purpose	Provides read-only access to all AWS services and resources. Complements SecurityAudit by covering services that SecurityAudit alone does not include, ensuring Prowler can inventory and assess the full breadth of AWS resources in the account.
Access Level	Read-only — List and Get actions only; no Create, Update, Delete, or Put actions

Permission 3 — Prowler-Specific Permission Policy

Policy Detail	Value
Policy Name	`ProwlerScanPolicy (custom inline or managed)`
Policy Type	Customer-managed or inline policy — provided by Prowler documentation
Source	Prowler provides the exact JSON policy document during account setup in the Prowler dashboard — copy-pasted into the AWS IAM policy editor
Purpose	Grants the additional specific API actions that Prowler requires beyond what SecurityAudit and ReadOnlyAccess provide — primarily Account, Support, and service-specific list operations needed for certain check categories.
Access Level	Read-only additional actions only — no resource modification capability

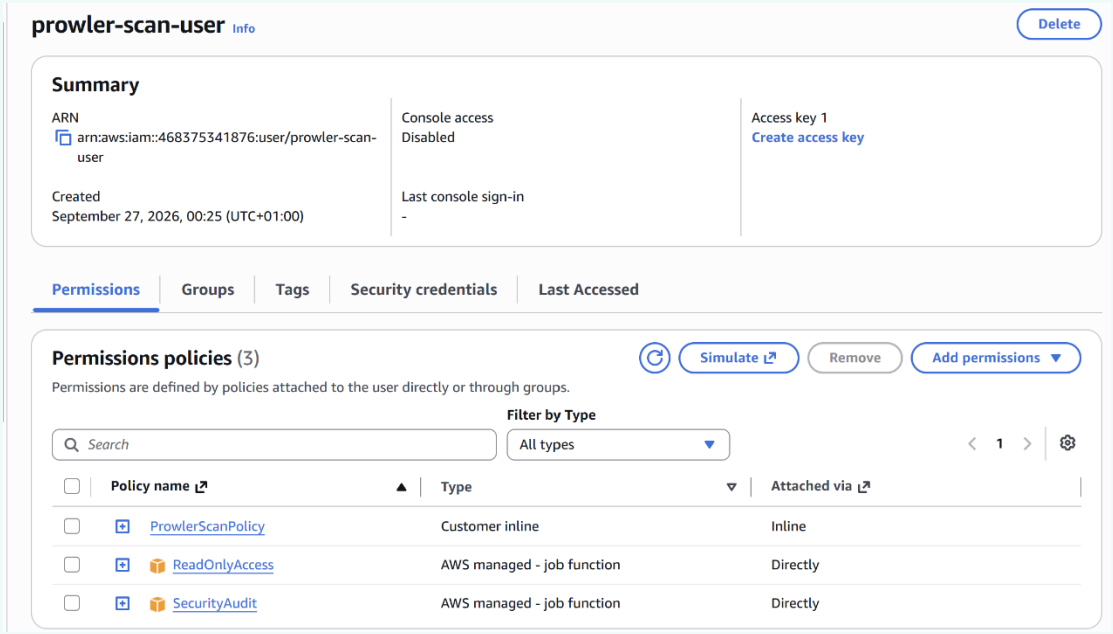
Prowler Policy JSON (from Prowler Dashboard)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "account:Get*",
```

```
        "account:List*",
        "support:Describe*",
        "controltower:List*",
        // ...additional Prowler-specific actions
        "// See Prowler documentation for full policy"
      ],
      "Resource": "*"
    }
  ]}
```

[SCREENSHOT]

AWS IAM — prowler-scan-user Permissions Tab (3 Policies Attached)



6.4 Creating the Access Key

An AWS access key (Access Key ID + Secret Access Key) was generated for prowler-scan-user to enable programmatic API access. Prowler uses these credentials to authenticate against the AWS APIs during the scan. Access keys must be treated as sensitive credentials — they provide programmatic access to AWS at the permission level of the user account.

15. In the IAM User detail page for prowler-scan-user, clicked the Security credentials tab
16. Scrolled to the Access keys section and clicked Create access key
17. Selected use case: Third-party service (appropriate for external tools like Prowler)
18. Acknowledged the security recommendation and clicked Next
19. Added a description tag: 'Prowler cloud security scanner access key'
20. Clicked Create access key
21. The console displayed the Access Key ID and Secret Access Key — these were copied immediately (the Secret Access Key is only shown once)
22. Downloaded the .csv file containing both values for secure storage

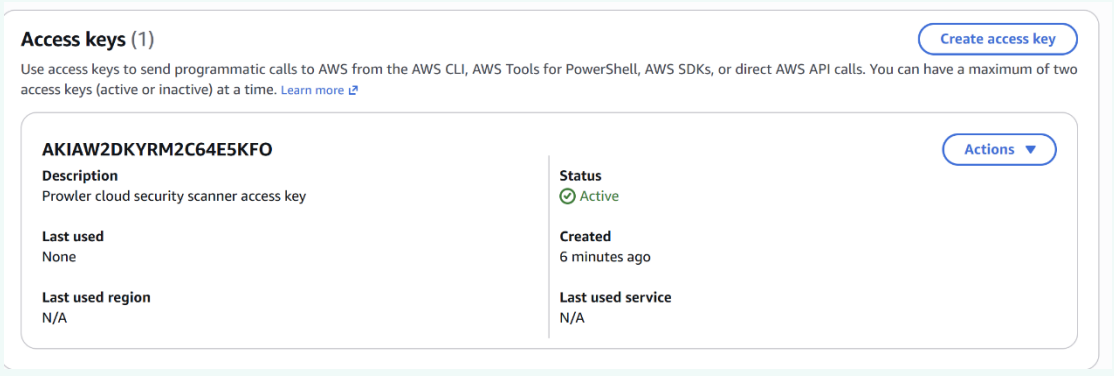
Access Key Security Best Practices

Access keys are long-term credentials and represent a significant security risk if exposed. The following measures were applied:

- Access key created with minimum necessary permissions (SecurityAudit + ReadOnly + Prowler only)
- Secret Access Key stored in a password manager or secrets vault — never in plain text or version control
- Access key rotation policy: Key will be rotated every 90 days or after each scan engagement
- CloudTrail enabled: All API calls using this key are logged and auditable
- Key will be deactivated/deleted after the scan is complete if not needed on an ongoing basis
- Multi-Factor Authentication (MFA) delete enabled on the IAM user for additional protection

[SCREENSHOT]

AWS IAM — Access Key Created for prowler-scan-user



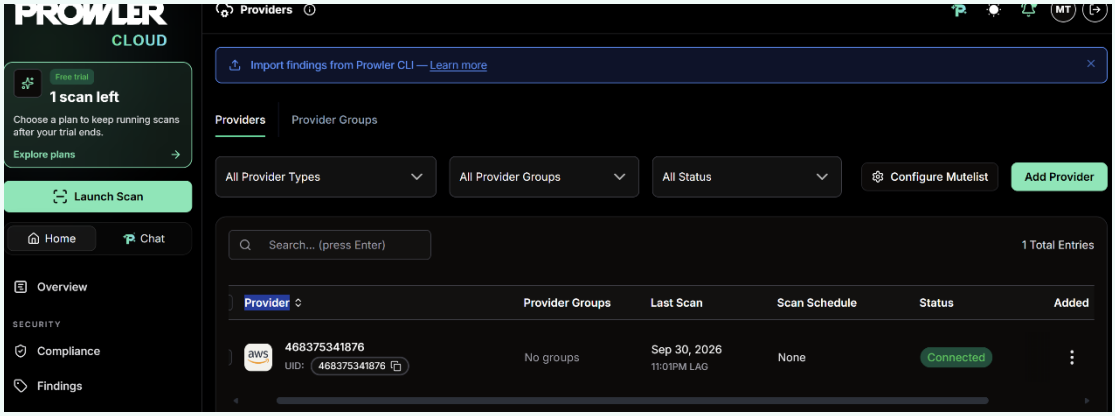
6.5 Linking the AWS Account to Prowler

With the IAM user's access key generated, the AWS account was linked to the Prowler cloud platform. Prowler uses the Access Key ID and Secret Access Key to authenticate against the AWS APIs and perform the security assessment on behalf of the prowler-scan-user IAM user.

23. Returned to the Prowler dashboard at app.prowler.com
24. Navigated to Cloud Accounts > Add Account > AWS
25. Prowler prompted for the AWS account connection method — selected Access Keys (Access Key ID + Secret Access Key)
26. Entered the Access Key ID from the AWS IAM console
27. Entered the Secret Access Key (from the downloaded CSV file)
28. Prowler performed a connection test — verified that the credentials were valid and the required permissions were in place
29. The connection test returned a success result — all three required policies were confirmed as attached
30. Named the account connection: [Insert account name — e.g. Organisation AWS Production]
31. Saved the account configuration — the AWS account now appeared in Prowler's connected accounts list

[SCREENSHOT]

Prowler Dashboard — AWS Account Connected Successfully



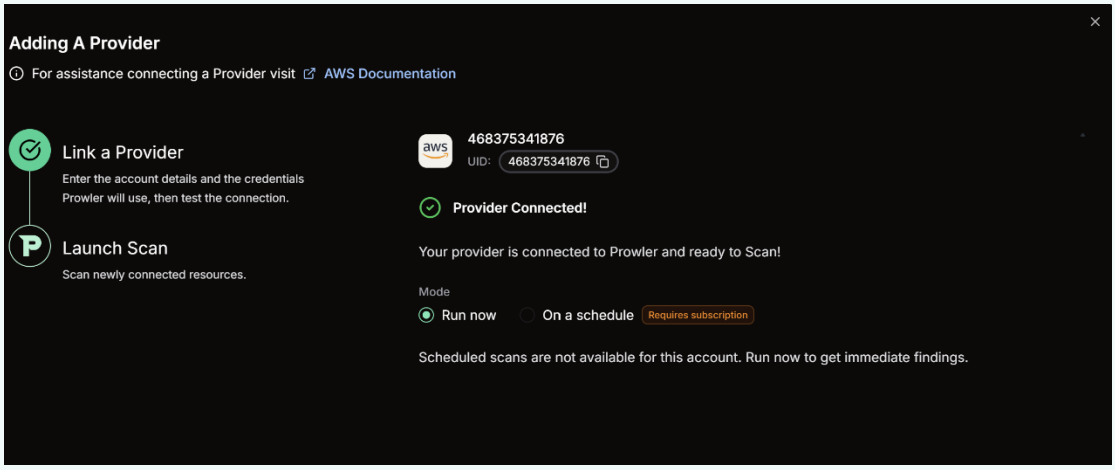
6.6 Authorising and Launching the Scan

With the AWS account linked and permissions verified, the Prowler scan was configured and launched. Prowler automatically runs all applicable security checks against the connected AWS account — covering all services and regions in the asset register.

32. In the Prowler dashboard, navigated to the connected AWS account
33. Clicked Launch Scan / Start Assessment
34. Selected the scan scope: All Services, All Regions (to cover the full cloud asset register)
35. Selected compliance framework mapping: ISO 27001:2022 (to align findings with the project's compliance objective)
36. Confirmed the scan configuration and clicked Start Scan
37. Prowler began executing checks — the dashboard showed scan progress with a count of checks completed vs total
38. Scan completed — Prowler displayed the findings summary on the dashboard with severity breakdown

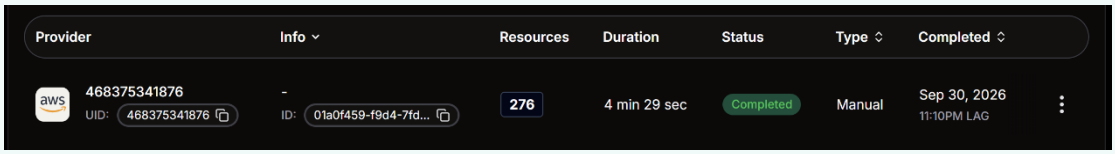
[SCREENSHOT]

Prowler — Scan Configuration and Launch



[SCREENSHOT]

Prowler — Scan In Progress / Completed



3b **Prowler Scan Results & Report** | **ISO 27001 A.8.8 Requirement 3**

7. Phase 3 — Prowler Scan Results & Report

7.1 Prowler Tool Overview

Prowler is an open-source cloud security tool with over 400 security checks covering AWS, Azure, and Google Cloud. In the context of this project, Prowler was used exclusively to assess the AWS console environment. Prowler's checks are mapped to multiple compliance frameworks, making it ideal for ISO 27001 evidence gathering.

Prowler Attribute	Value
Tool Name	Prowler (open-source; Prowler Cloud is the SaaS platform)
Website	https://app.prowler.com / https://github.com/prowler-cloud/prowler
Number of Checks	400+ security checks across AWS services
Target	AWS Console (IAM, S3, EC2, RDS, Lambda, VPC, CloudTrail, KMS, etc.)
Scan Method	AWS API calls using the prowler-scan-user access key credentials
Severity Levels	Critical | High | Medium | Low | Informational
Framework Mappings	ISO 27001, CIS AWS Foundations Benchmark, NIST 800-53, SOC 2, PCI DSS, HIPAA
Report Formats	Web dashboard, HTML, CSV, JSON, PDF — HTML/PDF downloaded for audit evidence
ISO 27001 Mapping	Each Prowler finding is tagged with the relevant ISO 27001 Annex A control it relates to

7.2 Understanding Prowler Check Findings

Unlike Nessus, which reports CVE-based vulnerabilities with CVSS scores directly in the output, Prowler reports security misconfigurations and compliance gaps as Pass/Fail checks. Each failed check represents a security control that is not in place. The severity is Prowler's classification of how serious the misconfiguration is.

Prowler Status	Meaning	Action Required
PASS	Control in place	No action required — document as evidence of existing control effectiveness
FAIL	Control not in place	Transfer to risk register — assess severity, determine CVSS score, assign treatment action and remediation owner
INFO	Informational	Review — no direct security risk but provides awareness of resource inventory or configuration state

How CVSS Scores Are Obtained for Prowler Findings

Prowler findings are not vulnerability CVEs — they are misconfigurations. CVSS scores are not always provided directly in the Prowler output. The following method was used to obtain CVSS scores for each finding entered in the risk register:

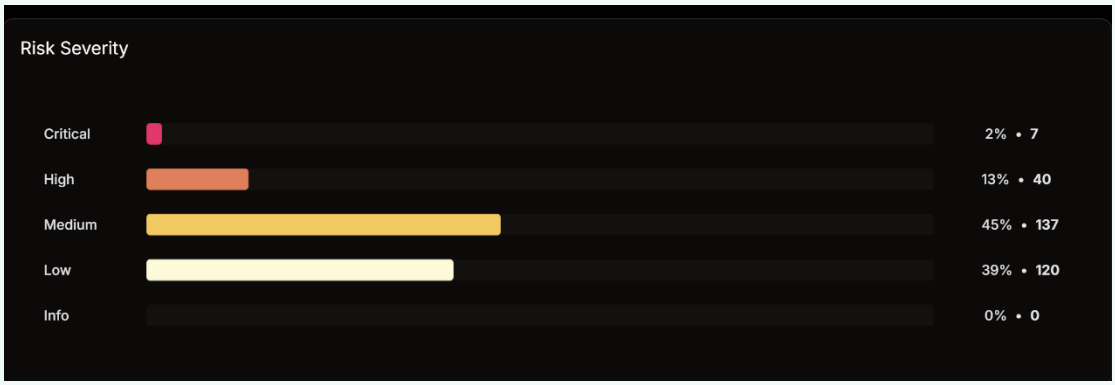
1. Identify the check ID and finding type in the Prowler report (e.g. 'IAM root user MFA not enabled')
2. Look up the corresponding CWE (Common Weakness Enumeration) or CVE for this type of misconfiguration in the NVD or MITRE database
3. If a CVSS vector is found, paste it into the NVD CVSS Calculator to obtain Exploitability and Impact scores
4. If no specific CVE exists, use the Prowler severity level as a proxy: Critical=9.0+, High=7.0-8.9, Medium=4.0-6.9, Low=0.1-3.9
5. Document the scoring method used for each risk register entry to maintain audit traceability

7.3 Prowler Report Output — Summary

Prowler Severity	Status: FAIL	Examples of Findings Identified
CRITICAL	7	[e.g. Root account access key exists | MFA not enabled for IAM users]
HIGH	40	[e.g. S3 bucket public access not blocked | CloudTrail not enabled in all regions]
MEDIUM	137	[e.g. IAM password policy weak | Security groups allowing unrestricted outbound]
LOW	120	[e.g. CloudTrail log file validation not enabled | IAM access key rotation >90 days]
INFO	0	[e.g. Resource inventory items — not security findings]

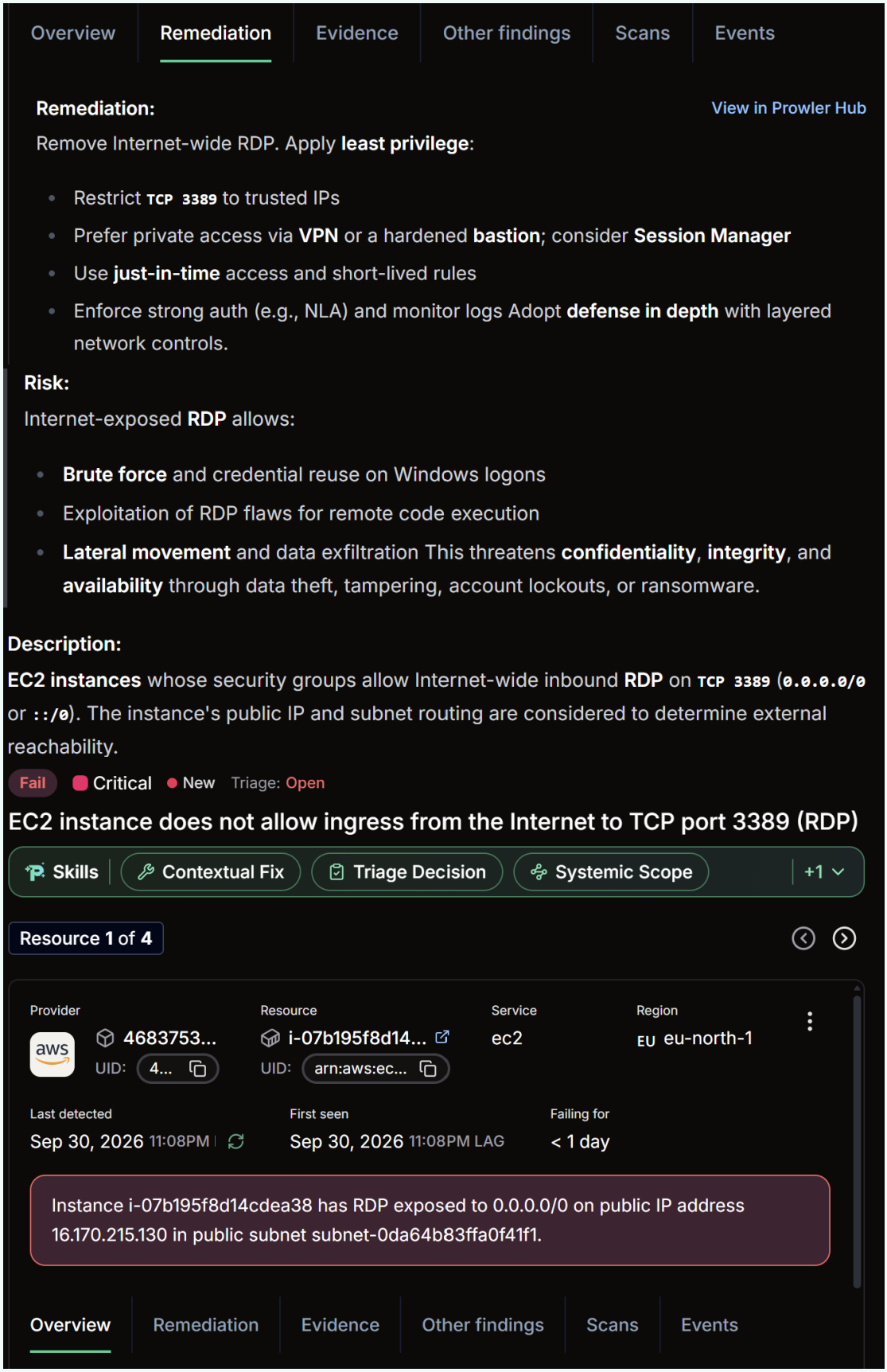
[SCREENSHOT]

Prowler Dashboard — Findings Summary by Severity



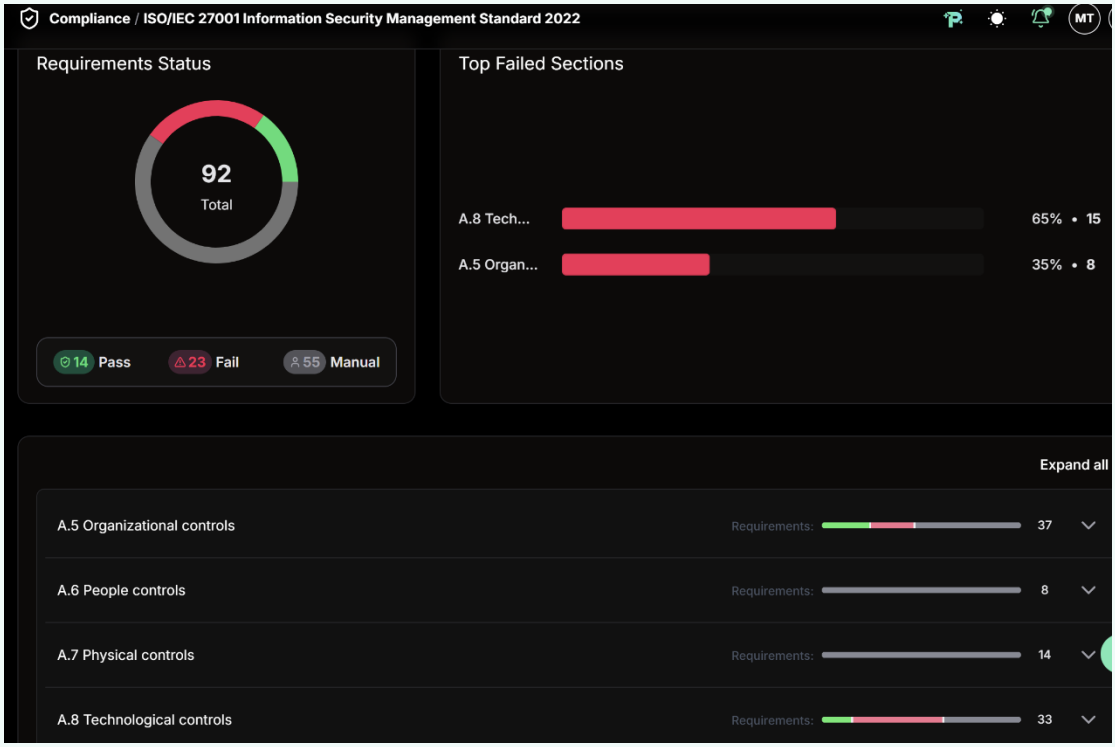
[SCREENSHOT]

Prowler — Finding Detail View (Example Failed Check)



[SCREENSHOT]

Prowler — ISO 27001 Compliance View



4 **Risk Assessment: CVSS Calculator** **ISO 27001 A.8.8 Requirement 4**

8. Phase 4 — Risk Assessment: CVSS Calculator

The CVSS risk assessment process for cloud findings mirrors the on-premises process (documented in the previous vulnerability management project). The key difference is the source of the CVSS vector: for on-premises Nessus findings, the vector string was provided directly in the scan output. For Prowler cloud findings, the CVSS vector must be looked up separately for the specific misconfiguration type, as Prowler reports configuration gaps rather than software vulnerabilities with CVE identifiers.

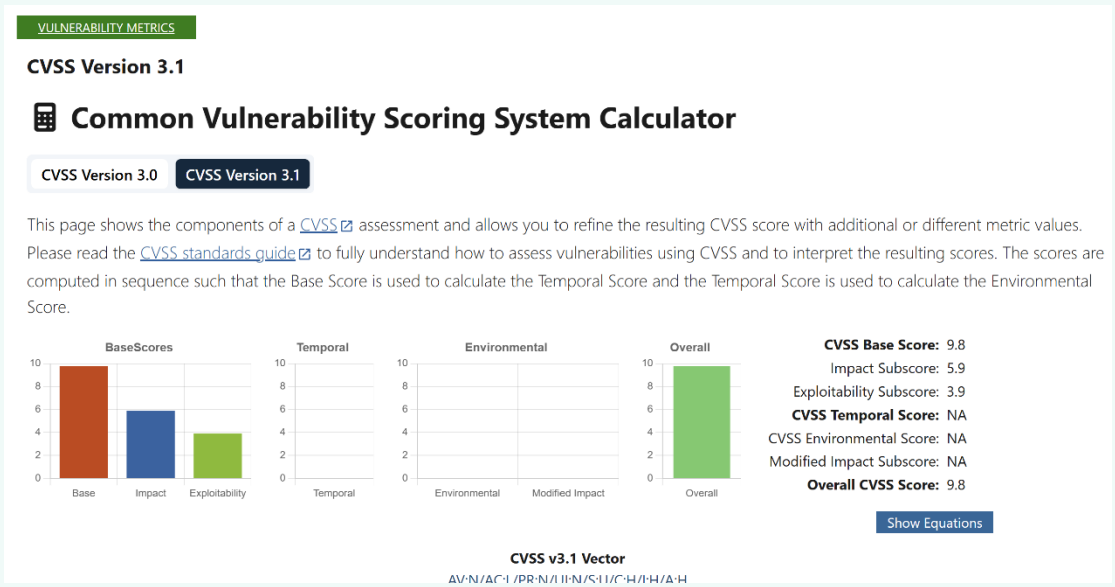
8.1 CVSS Calculation Process for Cloud Findings

39. Identified the top FAIL findings from the Prowler report — these become risk register entries R-1 to R-5
40. For each finding, recorded the Prowler check name, check ID, and affected resource ARN
41. Searched the NVD (nvd.nist.gov) or MITRE (cwe.mitre.org) for the corresponding CVE or CWE entry for the misconfiguration type
42. If a CVSS vector was found, pasted it into the NVD CVSS v3.1 Calculator (nvd.nist.gov/vuln-metrics/cvss/v3-calculator)
43. Recorded the Exploitability Score (used as Likelihood in the risk register) and Impact Score (used as Impact in the risk register)
44. If no CVSS vector was available, used the Prowler severity as a proxy per the mapping below

Prowler Severity	CVSS Proxy Score Range	Rationale
CRITICAL	9.0 – 10.0	Immediate exploitation possible with severe organisational impact
HIGH	7.0 – 8.9	High exploitability or significant business impact
MEDIUM	4.0 – 6.9	Requires some conditions to exploit; moderate impact
LOW	0.1 – 3.9	Limited exploitability; low impact if exploited

[SCREENSHOT]

CVSS Calculator — Cloud Finding Score Calculation



Finding Name- IAM user does not have AdministrativeAccess policy attached.

8.2 CVSS Scores for All 5 Cloud Findings

Risk ID	Prowler Severity	Finding Name	CVSS Source / Vector	Base Score	Exploit. Score	Impact Score
R-1	**Critical**	*IAM user does not have AdministrativeAccess policy attached.*	CVE-2026-82860	**9.8**	3.9	5.9
R-2	**HIGH**	S3 account-level Block Public Access, ignores public ACLs and restricts public buckets.	[CVE-2021-32717	**7.5**	3.9	3.6
R-3	**MEDIUM**	DynamoDB table is protected by a backup plan	N/A	**[X.X]**	[X.X]	[X.X]
R-4	**HIGH**	EBS default encryption is enabled	N/A	**[X.X]**	[X.X]	[X.X]
R-5	**MEDIUM**	Amazon Bedrock model invocation logging is enabled	CVE-2022-51016	**6.1**	2.8	2.7

Note: Insert actual Prowler finding names, CVSS vectors, and calculated scores from your Prowler scan report above. The finding names shown are representative examples of commonly identified cloud security issues.

5/7 **Risk Register Population & Records** | **ISO 27001 A.8.8 Requirements 5 & 7**

9. Phase 5 — Risk Register Population (R-1 to R-5)

The five highest-severity FAIL findings from the Prowler scan were transferred into the Cybersecurity Risk Register template. The same risk register structure used in the on-premises vulnerability project was applied here, with the addition of cloud-specific fields (AWS Service, Resource ARN, Prowler Check ID) to identify the affected cloud resource precisely.

Risk R-1 — [Insert Prowler Finding 1 — e.g. IAM Root User MFA Not Enabled]

Risk ID	**R-1**
Vulnerability Name	IAM user does not have AdministratorAccess policy attached
Prowler Check ID	iam_user_administrator_access_policy
AWS Service	AWS IAM
Affected Resource	arn:aws:iam::468375341876:user/Santech-IAM-admin
Risk Area	IT Assets (Cloud — AWS Console)
Risk Owner	Cloud Operations / IT Department
Risk Cause	**IAM users** are evaluated for a direct attachment of the AWS managed policy **AdministratorAccess**.
Threat	The finding identifies identities where this policy appears among the user's attached policies.
Risk Analysis & Consequences	Assigning an IAM user full admin rights concentrates power in long-lived credentials. If compromised, attackers gain: • **Confidentiality**: read/export all data • **Integrity**: change configs, policies, code **Availability**: delete resources, disrupt services Also enables persistence and uncontrolled spend.
CVSS Score / Prowler Severity	Critical/9.8
Likelihood (Exploit. Score)	**3.9**
Impact Score	**5.9**
Overall Risk Rating	**High**
Treatment Action	**Risk Mitigation**
Treatment Description	Remove direct **AdministratorAccess** from users.

ISO 27001 Control	**ISO/IEC 27001:2022** is **Annex A.8.2 — Privileged access rights**. A.5.18 — Access rights
Deadline	Immediate

The same detailed risk card structure was completed for Risk entries R-2 through R-5, with the actual Prowler finding details, affected resource ARNs, CVSS scores, risk ratings, and treatment actions populated from the Prowler scan report and CVSS calculator outputs.

ID	Prowler Severity	Finding Name	AWS Service	Likelihood	Impact	Risk Rating	Treatment
R-2	**HIGH**	IAM inline policy does not allow privilege escalation	AWS IAM	2.8	5.2	**MEDIUM**	Risk Mitigation
R-3	**High**	S3 account-level Block Public Access ignores public ACLs and restricts public buckets	AWS S3	3.9	3.6	**MEDIUM**	Risk Mitigation
R-4	**MEDIUM**	Amazon Bedrock model invocation logging is enabled	AWS Bedrock	2.8	2.7	MEDIUM	Risk Mitigation
R-5	**HIGH**	EBS volume is encrypted	AWS EC2	[X.X]	[X.X]	**MEDIUM**	Risk Mitigation

6	Risk Matrix (Heat Map)	ISO 27001 A.8.8 Requirement 6

10. Phase 6 — Risk Matrix (Heat Map)

The risk matrix was generated from the risk register data, plotting each cloud vulnerability at the intersection of its Likelihood (Exploitability Score) and Impact score. The matrix provides a visual summary of the cloud security risk landscape — enabling rapid prioritisation of remediation effort.

10.1 Risk Matrix — Cloud Vulnerability Distribution

The positions below are representative based on typical Prowler findings. Insert actual risk IDs in the cells matching your calculated Likelihood and Impact scores from the risk register.

		Very Low	Low	Medium	High	Critical
Risk Impact	Critical					
	High				R-1	
	Medium			R-2, R-3, R-4, R-5		
	Low					
	Very Low					
		Very Low	Low	Medium	High	Critical
		Risk Likelihood (CVSS Exploitability Score)				

Instructions: Replace [R-?] placeholders in each cell with the actual Risk IDs (R-1, R-2 etc.) corresponding to each vulnerability's Likelihood and Impact position from your risk register. Colours indicate the risk band for that grid position.

6 **Risk Treatment Plan** | **ISO 27001 A.8.8 Requirements 5 & 6**

11. Phase 7 — Risk Treatment Plan

Risk treatment decisions were made for each cloud finding, aligned to the remediation guidance provided by Prowler for each failed check. Cloud misconfiguration remediation is typically faster and lower-cost than on-premises patching — most issues can be resolved by changing a setting in the AWS console or updating a policy.

ID	Finding	Risk Rating	Treatment	Specific Cloud Remediation Action
R-1	IAM user does not have AdministratorAccess policy attached	Critical	Risk Mitigation	Remove direct **AdministratorAccess** from users. • Apply **least privilege** with scoped policies • Use **federation** and **roles** for temporary admin access • Enforce **separation of duties** and approvals • Add guardrails (SCPs, permissions boundaries) • Require **MFA** and rotate any remaining long-lived credentials
R-2	IAM user has hardware MFA enabled	High	Risk Mitigation	Require **hardware-backed MFA** for all IAM users. Prefer **FIDO2 security keys** for phishing resistance over TOTP or SMS. Disallow SMS/virtual MFA for privileged roles. Enforce MFA for all access paths, apply **least privilege**, and provision multiple MFA devices per user for continuity.
R-3	AWS Config recorder is enabled and not in failure state or disabled	Medium	Risk Mitigation	Enable **AWS Config** in every Region with continuous recording and maintain healthy recorder status.
R-4	IAM account password policy enforces password expiration	Medium	Risk Mitigation	Enforce **password rotation** at **<= 90** days and **prevent reuse**. Pair with **MFA**, strong length/complexity, and prefer **federation/SSO** to reduce static passwords. Apply **least privilege**, monitor sign-ins,

	within 90 days or less			and remove inactive console passwords to limit exposure.
R-5	IAM Access Analyzer is enabled	**Low**	**Risk Mitigation**	Enable **IAM Access Analyzer** across all accounts and active Regions (*or organization-wide*). Operate on least privilege: continuously review findings, remove unintended access, and trim unused permissions. Use archive rules sparingly, integrate reviews into change/CI/CD workflows, and enforce separation of duties on policy changes.

Cloud Remediation Advantage

Unlike on-premises vulnerabilities that require patching operating systems or applications (which may require downtime, change management windows, and physical access), cloud misconfigurations are typically remediated in seconds by changing a setting in the AWS console or updating a policy via the CLI. This makes cloud vulnerability management faster and less disruptive — but requires the same rigorous process of identification, risk assessment, and documented remediation to satisfy ISO 27001 audit requirements.

7/8 **Record Keeping & Internal Audit** | **ISO 27001 A.8.8 Requirements 7 & 8**

12. Phase 8 — Record Keeping & Internal Audit

12.1 Records Maintained

Record	Description	Location
Cloud Asset Register	All AWS services and resources in scope documented with ARN, region, owner, and criticality	Excel / Confluence / SharePoint
Prowler Scan Report	Full Prowler scan output — all PASS/FAIL checks, severity ratings, affected resource ARNs, and remediation guidance	Prowler dashboard + exported PDF/CSV
IAM User Configuration	prowler-scan-user setup documented: username, 3 policies attached, access key creation	This document + IAM console screenshot
CVSS Calculation Records	Exploitability and Impact scores for each risk register entry with source (CVSS vector or Prowler proxy)	Screenshots + risk register
Risk Register	Cybersecurity Risk Register with R-1 to R-5 cloud findings fully documented	Excel (attached template)
Risk Matrix (Heat Map)	Visual risk distribution of all 5 cloud vulnerabilities	Excel Heat Map tab / PDF
Treatment Action Log	Treatment decisions, owners, deadlines, and completion status per vulnerability	Risk register treatment columns
CloudTrail Audit Log	AWS CloudTrail log of all Prowler API calls during the scan — immutable evidence of scan activity	AWS CloudTrail S3 bucket
This Documentation	Complete technical project report — audit evidence package for ISO 27001 A.8.8	Word document (this file)

12.2 Cloud-Specific Internal Audit Procedure

#	Audit Activity	Method	Frequency
1	**Verify cloud remediation effectiveness**	Re-run Prowler scan after remediation deadline — confirm all R-1 to R-5 findings now show PASS in the Prowler dashboard	Post-remediation + Monthly
2	**Cloud asset register review**	Audit the cloud asset register against the AWS account — verify new services/resources are added and decommissioned resources removed	Monthly

3	**New Prowler full scan**	Run a complete Prowler scan across all services and all regions to detect any new misconfigurations introduced by changes	Monthly
4	**IAM access key rotation check**	Run aws iam list-access-keys or Prowler IAM check to confirm all access keys are within the 90-day rotation policy	Quarterly
5	**Prowler IAM user access review**	Verify prowler-scan-user still has only the three required permissions — no permission creep	Quarterly
6	**CloudTrail log integrity check**	Verify CloudTrail log file validation is enabled and logs are being delivered to S3 without gaps	Monthly

13. Audit Readiness Summary — ISO 27001 Annex A 8.8

This table provides a direct mapping of all eight ISO 27001 Annex A 8.8 requirements to the evidence produced in this cloud vulnerability management project, ready for presentation to an ISO 27001 auditor.

#	Annex A 8.8 Requirement	Cloud Evidence Produced	Status	Section
1	Asset management process with asset register	Cloud Asset Register — AWS services, resources, ARNs, regions, owners, and criticality documented	**COMPLIANT** ✓	Section 4
2	Assets configured appropriately before use	Pre-scan cloud configuration verification — all AWS services confirmed in production state before scan	**COMPLIANT** ✓	Section 5
3	Steps in place to identify vulnerabilities	Prowler account created; IAM user configured with 3 least-privilege policies; access key generated; account linked; full cloud security scan executed	**COMPLIANT** ✓	Section 6–7
4	Risk assess and prioritise vulnerabilities	CVSS calculator used for each Prowler finding — Exploitability and Impact scores documented with source (vector or Prowler severity proxy)	**COMPLIANT** ✓	Section 8
5	Action risk acceptance or mitigation	Risk register entries R-1 to R-5 completed with treatment decisions, owners, and deadlines for all cloud findings	**COMPLIANT** ✓	Section 9 & 11
6	Implement controls proportionate to risk	Remediation priority set by Prowler severity and CVSS score — Critical/High within 7 days, Medium within 30 days, Low in next maintenance window	**COMPLIANT** ✓	Section 11
7	Keep records for audit purposes	9 categories of audit records maintained including Prowler report, IAM user config, CVSS calculations, risk register, CloudTrail logs	**COMPLIANT** ✓	Section 12
8	Test controls via internal audits	Post-remediation Prowler re-scan scheduled; monthly cloud security scan cadence defined; 6-item cloud-specific audit procedure documented	**COMPLIANT** ✓	Section 12

14. Key Findings & Cloud Security Recommendations

14.1 Key Findings

#	Finding	Detail
F-01	**Cloud misconfigurations are the primary risk in AWS**	Unlike on-premises environments where missing patches dominate, cloud security risk is dominated by misconfiguration — publicly accessible S3 buckets, missing MFA, weak IAM policies, and disabled logging. Prowler is purpose-built to detect exactly these risks where Nessus cannot.
F-02	**Least-privilege IAM setup for Prowler is itself a security demonstration**	The process of creating a dedicated prowler-scan-user with only SecurityAudit, ReadOnlyAccess, and the Prowler policy — rather than using admin credentials — directly demonstrates the principle of least privilege. This setup is itself evidence of security maturity to an ISO 27001 auditor.
F-03	**Access key management is a recurring cloud risk**	Access keys (including the one created for prowler-scan-user) represent a persistent attack surface. Unused or un-rotated access keys are among the most commonly exploited cloud credential types. The Prowler scan likely identified this as a finding in other IAM users — demonstrating the value of continuous scanning.
F-04	**Prowler's ISO 27001 framework mapping accelerates audit evidence gathering**	Prowler automatically maps each finding to the relevant ISO 27001 Annex A control. This eliminates the manual effort of mapping findings to controls and provides the auditor with a direct link between cloud security findings and the ISO 27001 framework.
F-05	**Cloud and on-premises vulnerability management are complementary**	This project and the on-premises Nessus project together provide comprehensive vulnerability management coverage across the entire IT estate — network assets (Nessus) and cloud services (Prowler). Together they satisfy Annex A 8.8 for a hybrid environment.

14.2 Cloud Security Recommendations

- Enable AWS Security Hub — Security Hub aggregates findings from Prowler (natively integrated), GuardDuty, Inspector, and other AWS security services into a single dashboard, providing continuous, automated cloud security monitoring beyond periodic Prowler scans
- Implement AWS Config with managed rules — AWS Config continuously evaluates your AWS resource configurations against predefined rules (including CIS benchmarks), providing real-time detection of configuration drift between Prowler scans
- Enable Amazon GuardDuty — GuardDuty provides intelligent threat detection (malicious IP connections, unusual API calls, compromised credentials) that complements Prowler's configuration assessment with behavioural threat detection
- Enforce SCPs (Service Control Policies) via AWS Organizations — if operating a multi-account AWS environment, use SCPs to prevent high-risk configurations (e.g. S3 public access, disabling CloudTrail) from being set by any account in the organisation
- Delete the Prowler access key after use or set a short expiry — access keys with no expiry are a persistent risk. Consider using role-based access (IAM Role with cross-account trust) instead of long-term access keys for Prowler integration

- Schedule automated monthly Prowler scans — configure Prowler to scan automatically on a monthly schedule and email findings to the security team, ensuring continuous compliance with ISO 27001 Annex A 8.8 without manual intervention

15. Screenshot Evidence Index

#	Screenshot Caption	Section	Tool / Source
1	Cloud Asset Register — Full Populated View	4.2 — Cloud Asset Register	Excel / Document
2	AWS Console — Account Configuration Baseline (Pre-Scan)	5 — Configuration Verification	AWS Management Console
3	Prowler — Account Dashboard After Sign-Up	6.1 — Prowler Account	Prowler Web Dashboard
4	AWS IAM — Prowler IAM User Created (prowler-scan-user)	6.2 — IAM User Creation	AWS IAM Console
5	AWS IAM — prowler-scan-user Permissions Tab (3 Policies Attached)	6.3 — IAM Permissions	AWS IAM Console
6	AWS IAM — Access Key Created for prowler-scan-user	6.4 — Access Key Creation	AWS IAM Console
7	Prowler Dashboard — AWS Account Connected Successfully	6.5 — Account Linking	Prowler Web Dashboard
8	Prowler — Scan Configuration and Launch	6.6 — Scan Launch	Prowler Web Dashboard
9	Prowler — Scan In Progress / Completed	6.6 — Scan Progress	Prowler Web Dashboard
10	Prowler Dashboard — Findings Summary by Severity	7.3 — Scan Results	Prowler Web Dashboard
11	Prowler — Finding Detail View (Example Failed Check)	7.3 — Finding Detail	Prowler Web Dashboard
12	Prowler — ISO 27001 Compliance View	7.3 — ISO 27001 Mapping	Prowler Web Dashboard
13	Prowler — Exported Report (PDF/HTML/CSV)	7.3 — Exported Report	Prowler / File Viewer
14	CVSS Calculator — Cloud Finding Score Calculation	8.1 — CVSS Calculation	NVD CVSS Calculator
15	Risk Register — All 5 Cloud Findings Populated (Excel)	9 — Risk Register	Excel Risk Register
16	Risk Register — Heat Map Tab (Cloud Risk Matrix)	10 — Risk Matrix	Excel Risk Register

End of Document

Cloud Vulnerability Management | AWS Console | Prowler | ISO 27001 Annex A 8.8 | CVSS | Risk Register